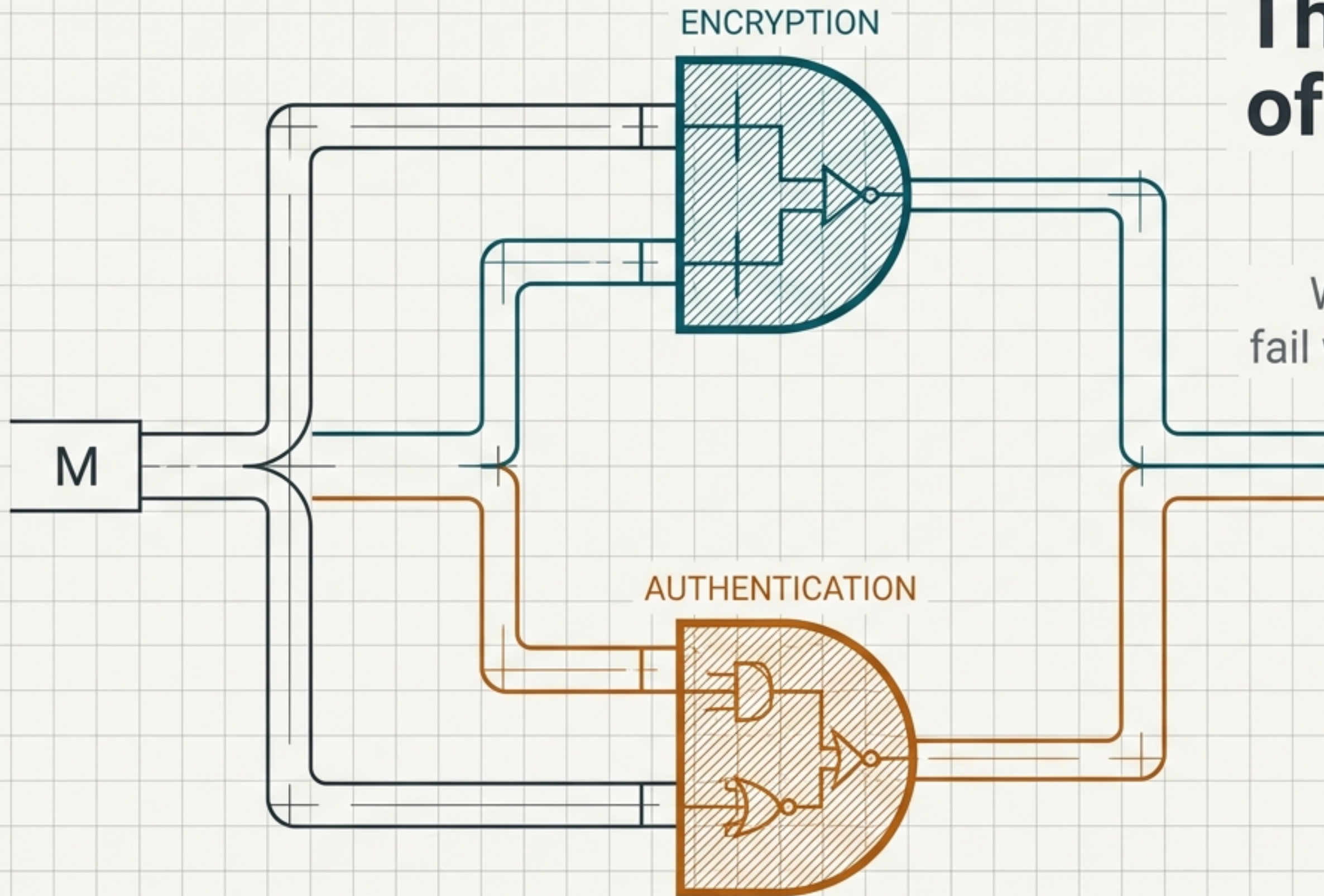


The Architecture of Authenticated Encryption

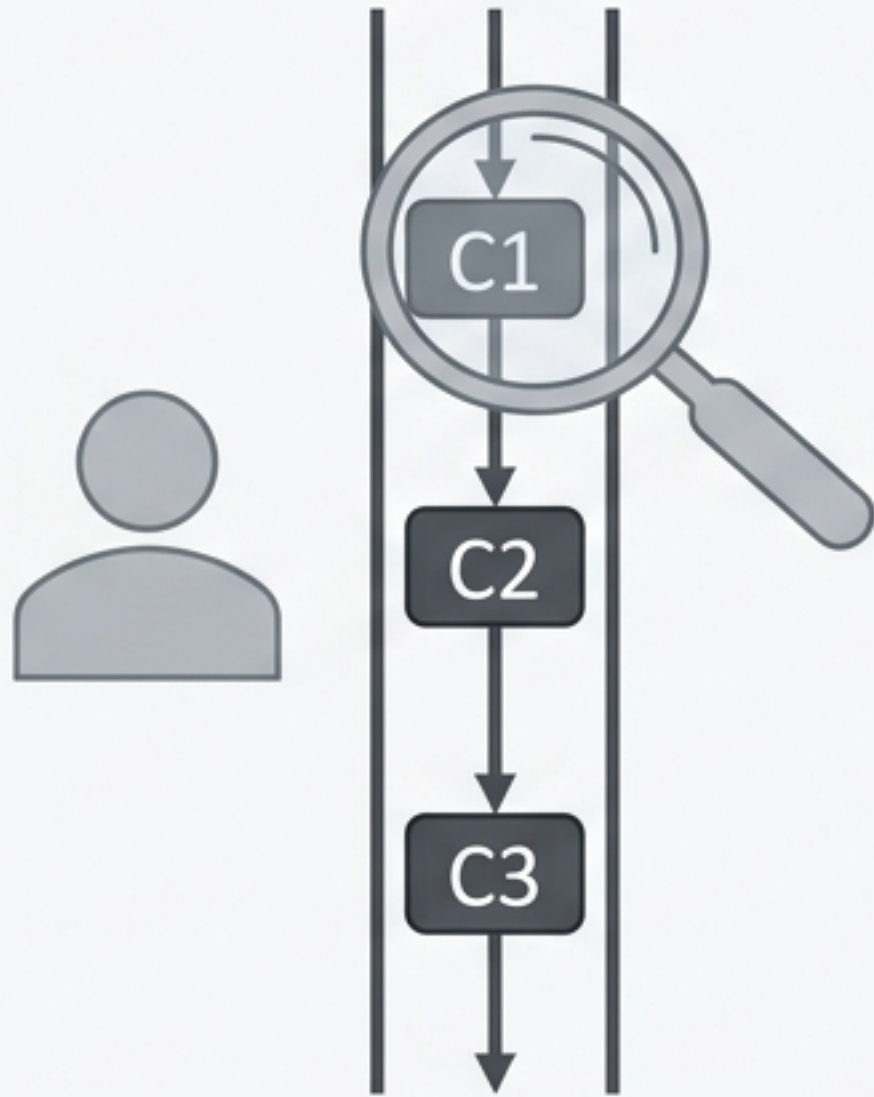
Why cryptographic primitives fail without secure composition.



KEY INSIGHT:
Confidentiality
without integrity
is structurally
compromised.

The Paradigm Shift: From Observation to Manipulation

Passive Adversary

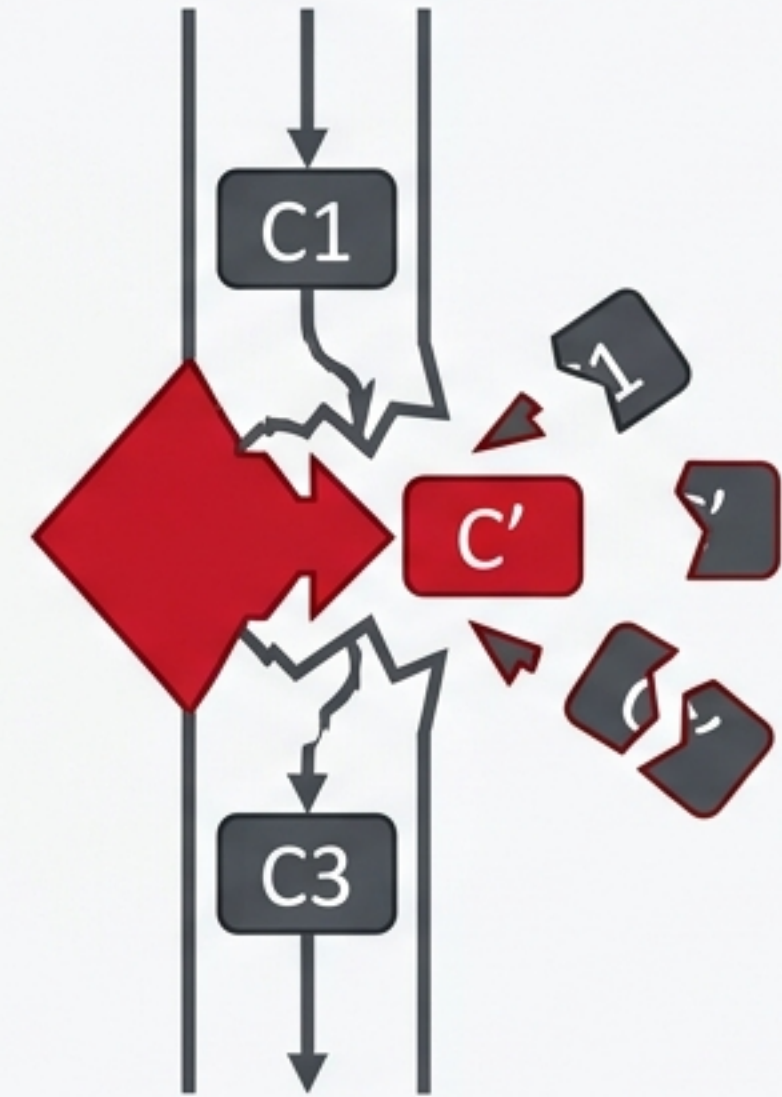


Observes $C = \text{Enc}_K(M)$.

Goal: Extract M via observation.

Addressed by standard indistinguishability.

Active Adversary

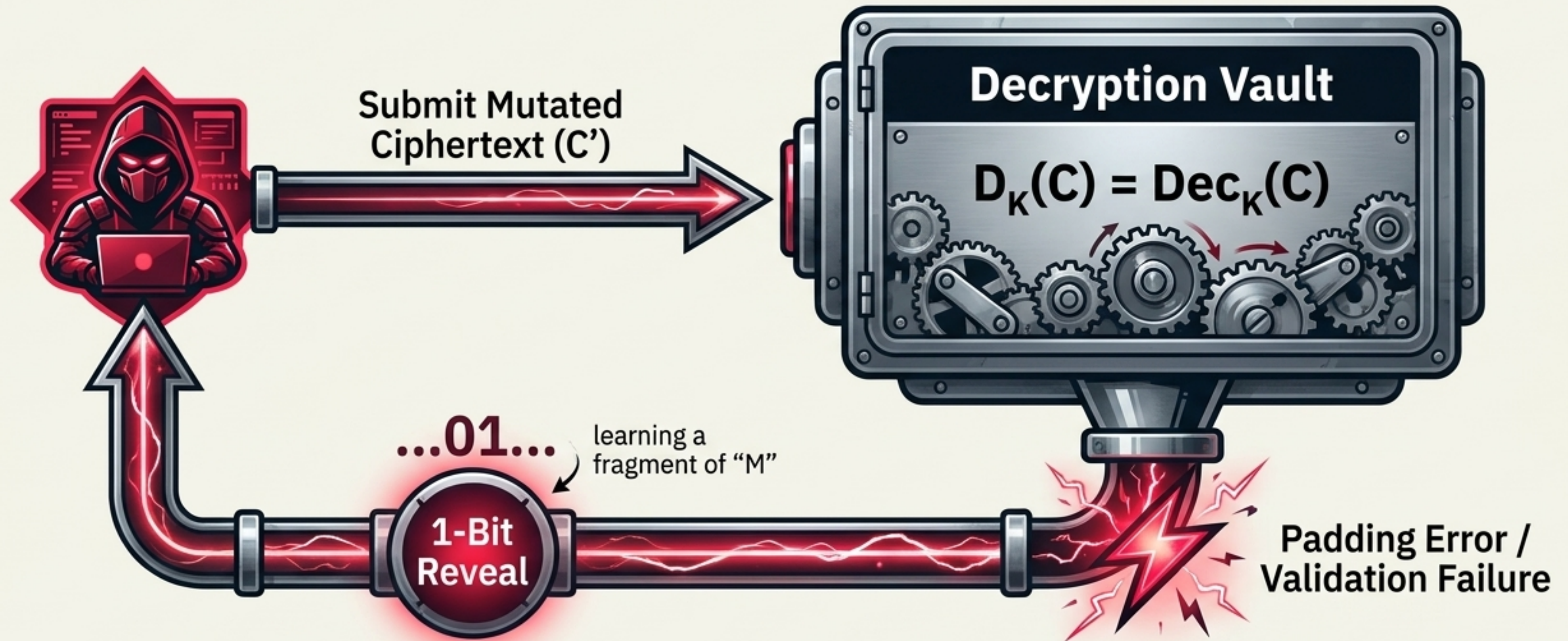


Intercepts, injects, and transforms $C \rightarrow C'$.

Goal: Force the receiver's system to act as a decryption oracle.

The Chosen-Ciphertext Attack (CCA) Engine

Adversary submits C' to learn if challenge C^* encrypts M_0 or M_1 .
Advantage: $|\Pr[b'=b] - 1/2|$



The attacker does not need the secret key. They use the receiver's decryption logic to perform computations under that key on their behalf.

The Primitives Toolkit

Cryptographic Hash Function



$$H: \{0,1\}^* \rightarrow \{0,1\}^n$$

Message Authentication Code (MAC)



$$T = \text{MAC}_K(M)$$

Symmetric Encryption



$$C = \text{Enc}_K(M)$$

- No Key Required
- NO Confidentiality
- NO Authentication (Anyone can compute)
- Output: Fixed-length digest (Collision resistant)

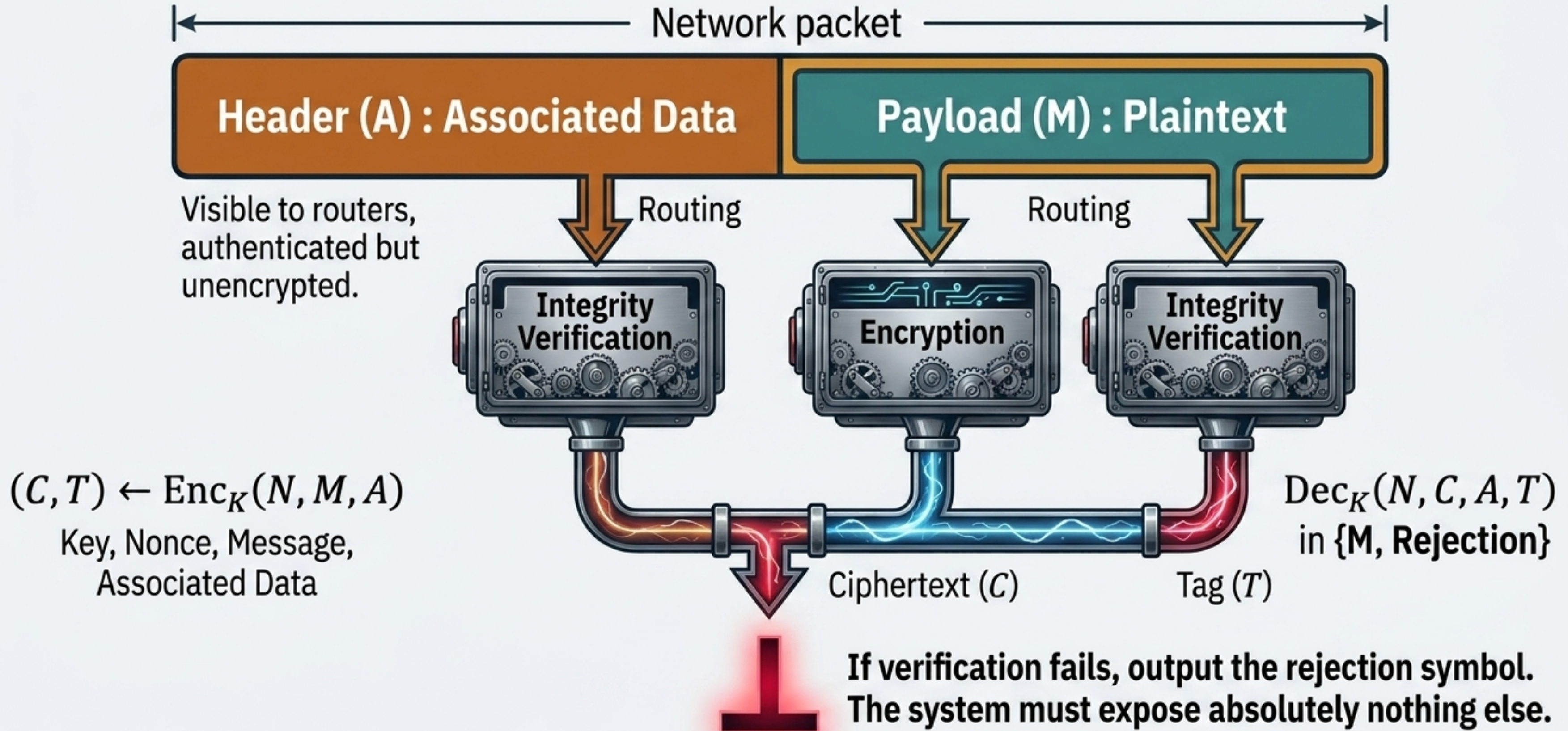
- Secret Key Required
- NO Confidentiality
- YES Integrity (EUF-CMA security) ✓
- Output: Tag

- Secret Key Required
- YES Confidentiality ✓
- NO Integrity
- Output: Ciphertext

Key Takeaway

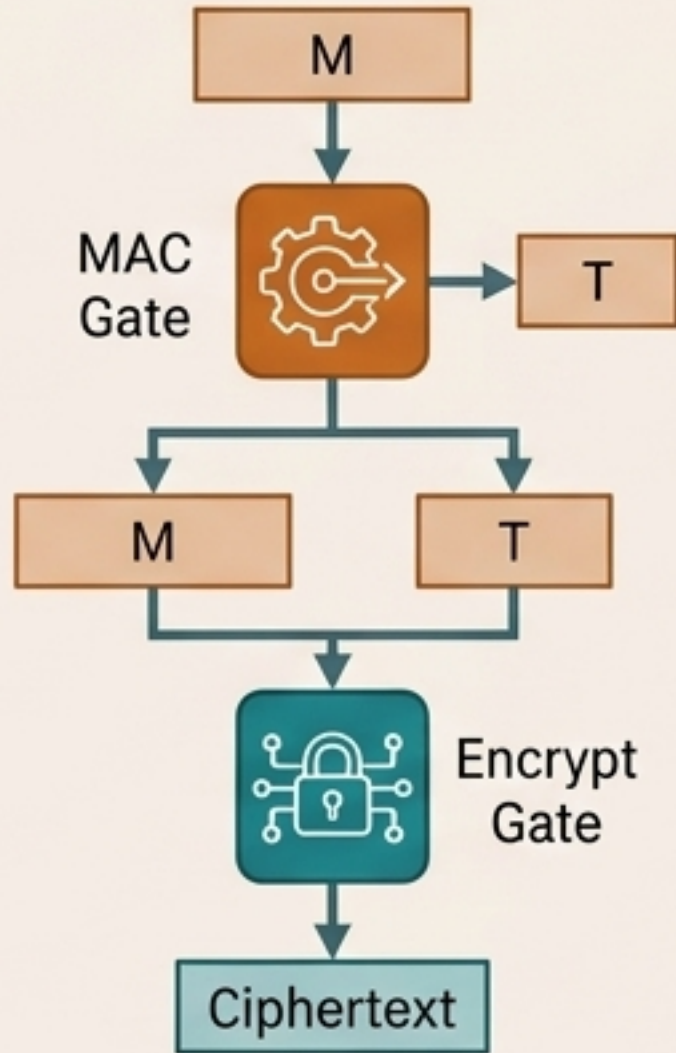
A MAC adds a secret key to integrity, but neither MACs nor Encryption can solve CCA alone.

Defining the AEAD Standard



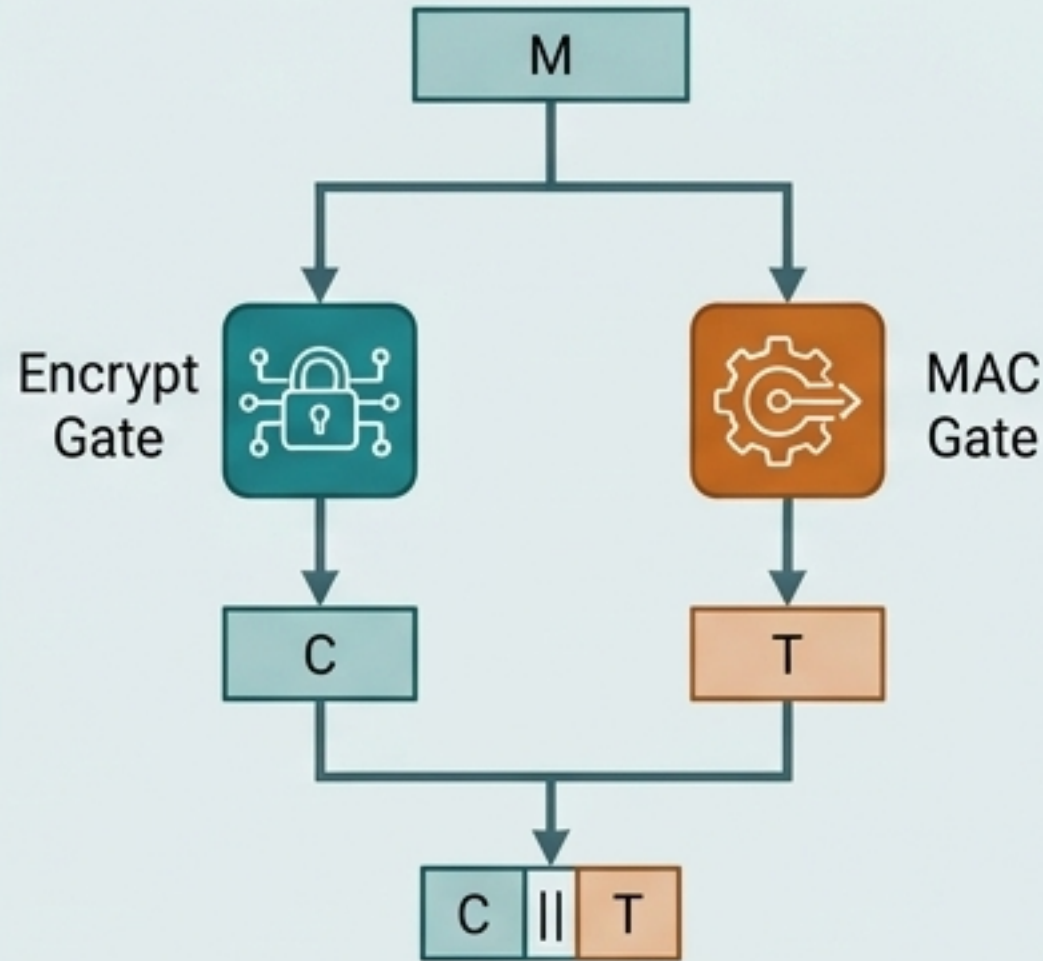
The Composition Showdown

MAC-then-Encrypt



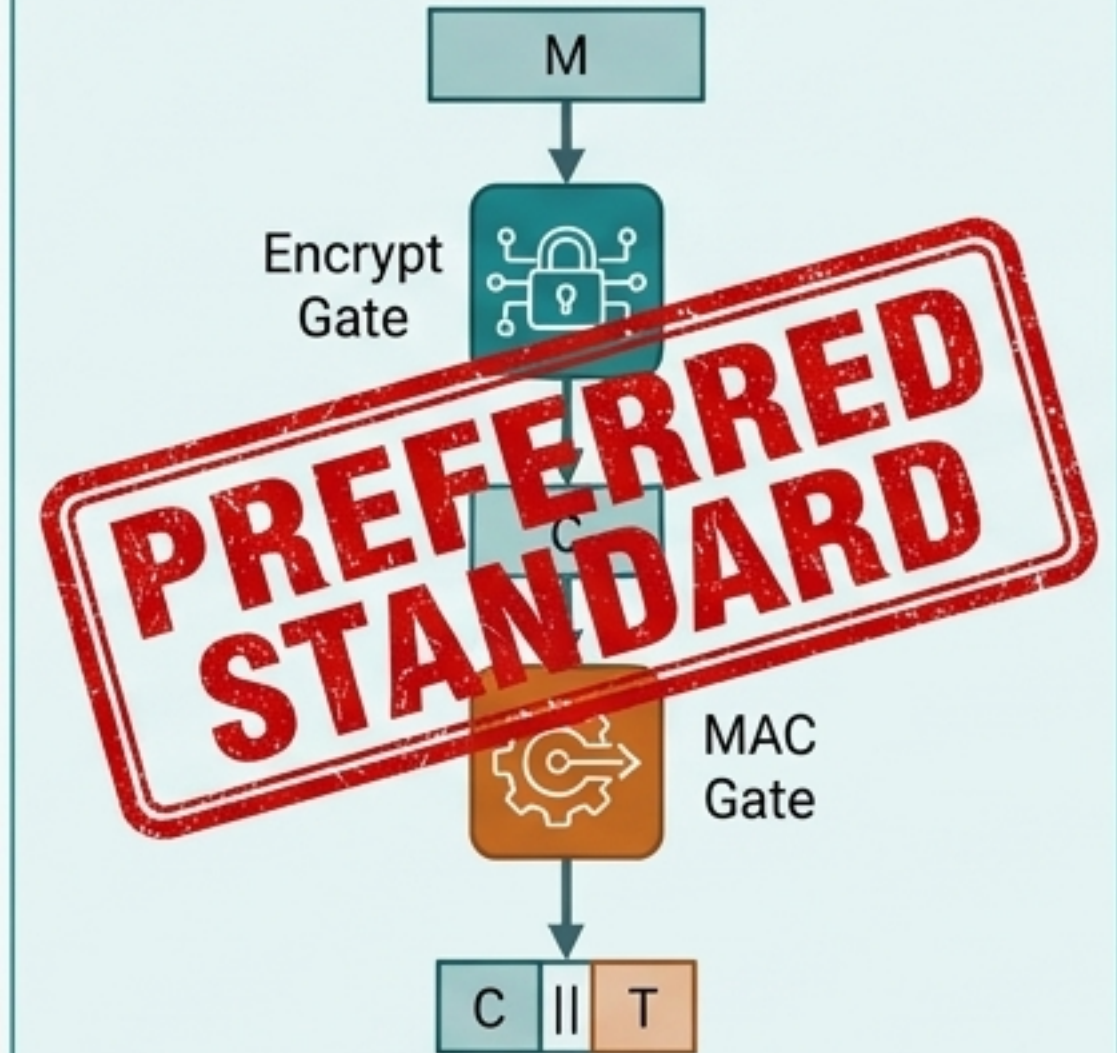
- Process Order: $\text{MAC}(M)$ then $\text{Enc}(M||T)$
- Decryption Protection: None (Decrypted before verified)
- Historical Status: TLS Legacy (Vulnerable)

MAC-and-Encrypt



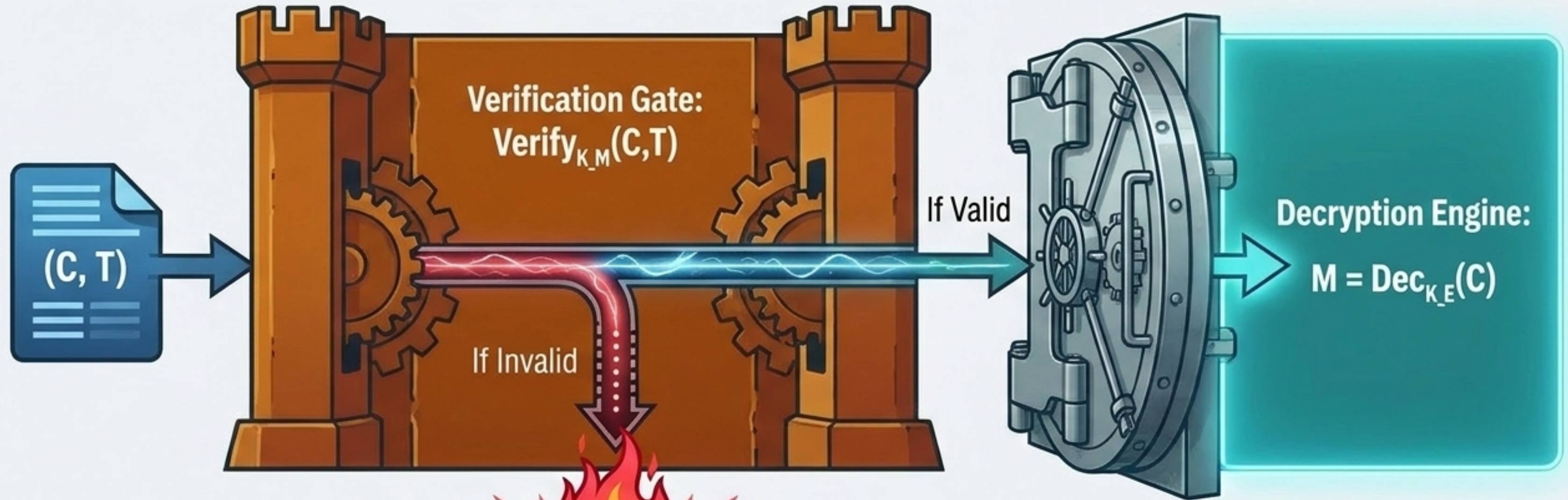
- Process Order: $\text{Enc}(M)$ & $\text{MAC}(M)$ independently
- Decryption Protection: Partial (Tag exposed)
- Historical Status: SSH Legacy

Encrypt-then-MAC (EtM)



- Process Order: $\text{Enc}(M)$ then $\text{MAC}(C)$
- Decryption Protection: Absolute
- Historical Status: Modern Standard

The Gatekeeper: **Encrypt-Then-MAC**



Zero Exposure

Decryption logic is physically unreachable by attacker-controlled ciphertexts.



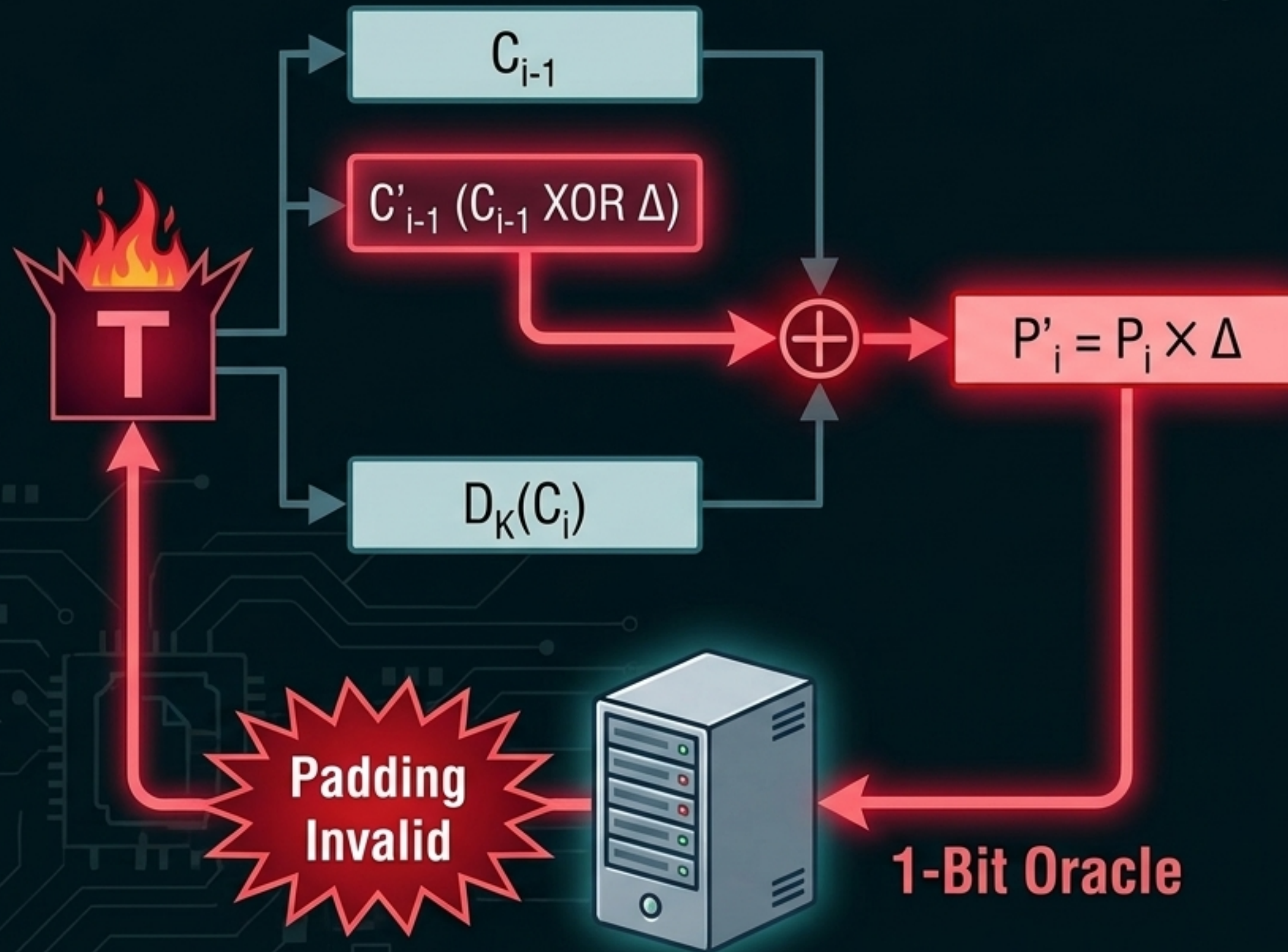
Sever connection immediately.

Authenticate the ciphertext before decrypting it.

Key Separation

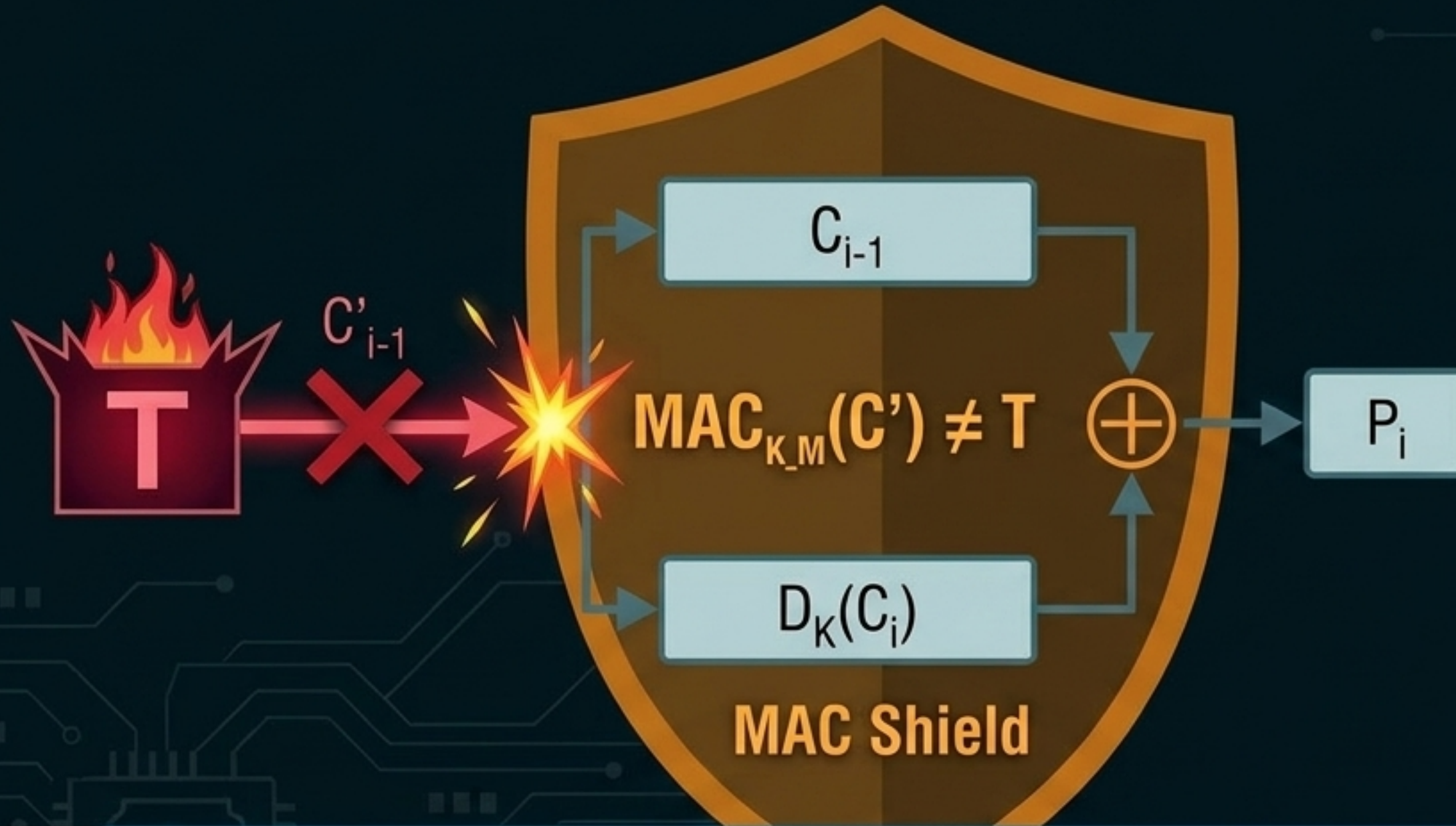
Uses independent keys (K_E and K_M) to prevent primitive interference.

The Proof: **CBC Padding Oracle Attacks**



1. Server decrypts and checks padding before verifying the MAC.
2. Attacker modifies the previous ciphertext (C_{i-1}) to inject a difference (Delta) into the plaintext (P'_i).
3. By monitoring padding rejections, the attacker recovers the plaintext byte by byte—without the key.

How EtM Neutralizes the Oracle



1. Server decrypts and checks padding before verifying the MAC.
2. Attacker modifies the previous ciphertext (C_{i-1}) to inject a difference (Delta) into the plaintext (P'_i).

Because $T = MAC_{K_M}(C)$, any manipulation of the ciphertext invalidates the tag. The system aborts immediately, yielding no padding information, permanently closing the oracle.

Standardized AEAD Modes

	GCM (Galois/Counter Mode)	CCM (Counter with CBC-MAC)	EAX
Encryption	Counter Mode (CTR)	Counter Mode (CTR)	Counter Mode (CTR)
Authentication	GHASH over finite field $GF(2^{128})$	CBC-MAC	OMAC/CMAC-like
Profile	High performance, highly parallelizable, universally adopted standard.	Unified classical constructions; heavily utilized in constrained and embedded wireless environments.	Explicitly authenticates associated data via $T = T_N \text{ XOR } T_A \text{ XOR } T_C$.

Common Denominator: All three unite CTR-mode confidentiality with integrated ciphertext and associated-data integrity.

The Catastrophe of **Nonce Reuse**

Stream 1: $C_1 = M_1 \text{ XOR } S$

Stream 2: $C_2 = M_2 \text{ XOR } S$

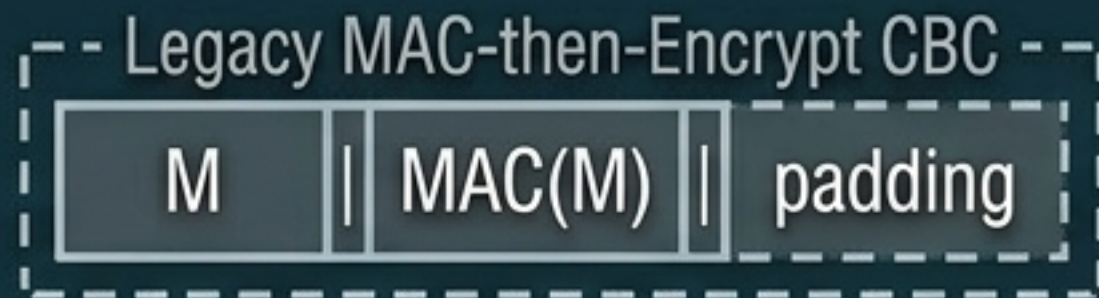


$$C_1 \text{ XOR } C_2 = M_1 \text{ XOR } M_2$$

- In modes like GCM, the nonce (J_0) ensures a unique keystream for every single encryption.
- If a nonce is reused under the same key, the identical keystreams cancel out entirely, directly exposing the XOR difference of the underlying plaintexts.
- **Authentication Collapse:** Nonce reuse in GCM also leaks algebraic information, allowing attackers to forge GHASH authentication keys.

The Crucible of **Real-World Protocols**

Transport Layer Security (TLS)

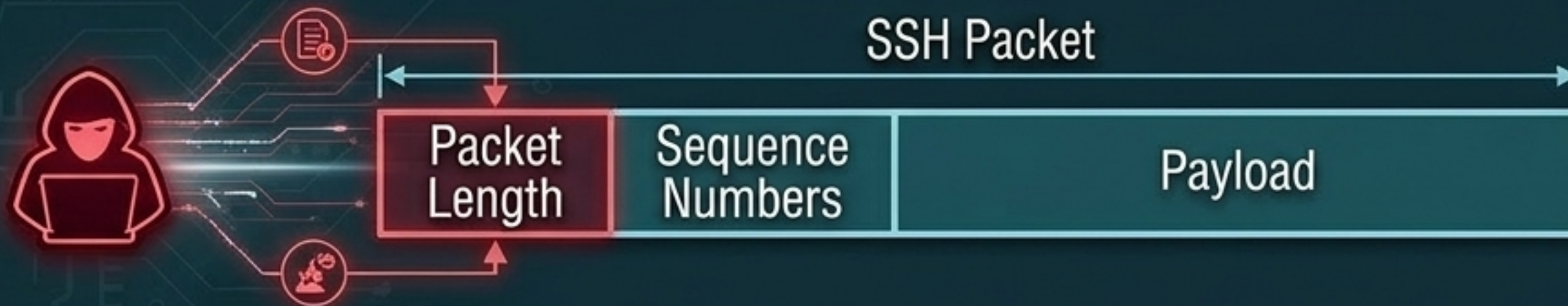


AES-GCM / ChaCha20-Poly1305

Legacy MAC-then-Encrypt CBC cipher suites created dangerous interactions between padding, error handling, and authentication, forcing the modern migration to dedicated AEAD.

Secure Shell (SSH)

SSH Packet



Early constructions allowed active attackers to manipulate packet length boundaries. Modern SSH ties encryption tightly to packet formats and rigid state machines.

Cryptography cannot be analyzed as an isolated mathematical function. Attackers exploit implementations, error messages, and state machines.

The **Composition Mandate**

The Flawed Assumption



Encryption



Integrity

Secure Primitives $\neq$ Secure System

The AEAD Law



Ordered Composition = AEAD

A cryptographic primitive can be mathematically secure while its protocol composition is structurally catastrophic.

- ✓ 1. Confidentiality without integrity fails against active attackers.
- ✓ 2. Decryption logic must be shielded behind authentication.
- ✓ 3. The security boundary is the composition, not the cipher.